

HelixQA Script §6.W Mirror-Policy Audit

Last verified: 2026-05-16 (Phase 4 follow-up B — Option 1 open question #4 resolution) **Inheritance:** Lava CLAUDE.md §6.W (GitHub + GitLab Only Remote Mandate) + §6.J (Anti-Bluff Functional Reality) + §6.AE (Comprehensive Challenge Coverage) **Classification:** project-specific (the per-script verdicts are Lava-specific; the audit-doc-as-anti-bluff-evidence pattern is universal per HelixConstitution §11.4.32)

Purpose

`scripts/run-helixqa-challenges.sh` invokes 11 HelixQA Challenge scripts at `submodules/helixqa/challenges/scripts/`. HelixQA is owned by the HelixDevelopment organization and may evolve independently — any future addition that pushes artifacts to a non-GitHub / non-GitLab mirror would silently violate Lava's §6.W mirror-host boundary if invoked through the wrapper without re-audit.

This document is the per-script audit + the EXCLUSIONS source-of-truth referenced by the `HELIXQA_W_EXCLUSIONS` constant in `scripts/run-helixqa-challenges.sh`. Per §6.J: real grep results only — no manufactured findings.

Audit methodology

For each script under `submodules/helixqa/challenges/scripts/`:

1. **Push targets** — `grep -nE 'git[[:space:]]+push' <script>`
2. **External HTTP services** — `grep -nE 'curl|wget' <script>` + inspection of the URL host(s)
3. **Filesystem writes outside the HelixQA worktree** — `grep -nE '^[a-zA-Z_-] (/ [a-zA-Z] [^[:space:]]+)' <script>` filtered for write destinations vs. read paths (e.g. `/etc/systemd/sleep.conf` is READ-only — a probe, not a write)
4. **§6.W verdict:**
 - **COMPLIANT** — no remote pushes; no calls to non-localhost / non-GitHub / non-GitLab services; no fs writes outside HelixQA worktree or /tmp
 - **REQUIRES-EXCLUSION** — would violate §6.W if invoked through the Lava wrapper; goes in `HELIXQA_W_EXCLUSIONS`
 - **HOST-MUTATION-RISK** — does NOT push remotely but mutates host system state outside the worktree (e.g. writes to `/etc/`); flagged but not §6.W-blocked because §6.W is about REMOTE mirrors, not local fs

Per-script findings

#	Script	Pushes?	External services	Outside-writes
1	anchor_manifest_challenge.sh	none	none	none (read {ROOT_DIR} / {ROOT_DIR}/challenge/baseline)
2	bluff_scanner_challenge.sh	none	none	none (invokes {ROOT_DIR}/anti-bluff/run-fixup.sh {ROOT_DIR}/anti-bluff/scanner HelixQA)
3	chaos_failure_injection_challenge.sh	none	curl against \$ {HELIXQA_HEALTH_URL:-http://localhost:8081/health} (LOCAL by default) + raw TCP via /dev/tcp/\$CHAOS_HOST/\$CHAOS_PORT (default localhost)	none
4	ddos_health_flood_challenge.sh	none	curl against \$ {HELIXQA_HEALTH_URL:-http://localhost:8081/health} (LOCAL by default)	none
5	host_no_auto_suspend_challenge.sh	none	none	READS /systemd/sleep.conf + /etc/sleep.conf + /etc/sleep.conf logind.journald probe; reads /systemd/sleep.conf suspend marker check a write
6	mutation_ratchet_challenge.sh	none	none (uses go-mutesting locally + git -C "\$ {ROOT_DIR}" for local-only diff against	none (writes mutesting HelixQA)

#	Script	Pushes?	External services	Outside-writes
7	no_suspend_calls_challenge.sh	none	BASE_BRANCH — no remote fetch / push) none (pure tree-walking grep)	none
8	scaling_horizontal_challenge.sh	none	curl against per-instance \$u/health URLs from HELIXQA_SCALE_URLS env (LOCAL by convention; operator-supplied)	none
9	stress_sustained_load_challenge.sh	none	curl against \${HELIXQA_HEALTH_URL:-http://localhost:8081/health} (LOCAL by default)	none
10	ui_terminal_interaction_challenge.sh	none	none	none (inv helixqa {SCRIPT bin/hel HelixQA helixqa binary ab
11	ux_end_to_end_flow_challenge.sh	none	none	none (san binary lo

Aggregate verdict

0 of 11 scripts violate §6.W on their default configuration.

All 11 scripts are §6.W-compliant when invoked through the Lava wrapper with default environment. Therefore the HELIXQA_W_EXCLUSIONS array in scripts/run-helixqa-challenges.sh is currently EMPTY — no scripts are pre-excluded. The wrapper invokes every script that operator's --only filter (or the absence thereof) selects.

Operator-supplied env-var risk surface

Five scripts (#3 chaos, #4 ddos, #8 scaling, #9 stress, and to a lesser extent the chaos raw-TCP target) honor operator-supplied environment variables that default to localhost. If an operator overrides any of these to point at a REMOTE service:

Env var	Default	Override risk
HELIXQA_HEALTH_URL	http://localhost:8081/health	Pointing at a remote service turns benign healthcheck into unauthorized traffic generation

Env var	Default	Override risk
		against a 3rd-party domain — §6.W violation (the "remote" is not GitHub/GitLab) AND a potential legal violation (DDoS test against an unauthorized target).
CHAOS_HOST / CHAOS_PORT	localhost / 8081	Same risk class as above — raw-TCP fuzzing of an unauthorized target.
HELIXQA_SCALE_URLS	unset (operator MUST supply)	Each URL MUST be local-only or point at an instance the operator owns.

The Lava wrapper does NOT validate these env vars — they are HelixQA-internal. Per §6.J the wrapper records this risk surface in this audit doc rather than silently sanitizing or rejecting (sanitizing would be a bluff — the operator might have a legitimate use; rejecting at the wrapper would override HelixQA's documented contract). Operator's standing responsibility per §6.W.

Re-audit triggers

This audit MUST be re-run when ANY of the following changes:

1. The submodules/helixqa pin bumps (because the script set may have changed — new scripts added, existing scripts changed). The scripts/run-helixqa-challenges.sh wiring-drift check catches added/removed scripts at runtime, but the §6.W audit of the script BODIES is a separate concern.
2. A new HELIXQA_* env var ships with a remote default (currently none do).
3. Any script grows a git push invocation (currently none have it).
4. Any script grows a curl / wget to a non-localhost default (currently none have it).

The re-audit is mechanical: re-run the methodology section's 4 grep queries against the new pin and update the per-script findings table. The wrapper exits 3 with a clear wiring-drift message if new scripts appear, prompting the operator to re-run this audit.

Cross-references

- scripts/run-helixqa-challenges.sh — the wrapper that consumes HELIXQA_W_EXCLUSIONS
- docs/scripts/run-helixqa-challenges.sh.md — wrapper user guide (references this audit)
- docs/helix-constitution-gates.md — CM-HELIXQA-§6.W-AUDIT gate row references this audit as the source-of-truth
- submodules/helixqa/challenges/scripts/ — the 11 scripts audited
- Lava CLAUDE.md §6.W (GitHub + GitLab Only Remote Mandate) + §6.J (Anti-Bluff Functional Reality)